bedrijfslogo

Interne procedures voor Informatiebeveiliging

[BEDRIJF]
Versie: [MAAND] 2021 [VERSIE]
Goedgekeurd door management: NOG NIET GOEDGEKEURD

Inhoudsopgave

Inhoudsopgave 2
Over dit document 3
Over dit template: 4
Inzicht in context en organisatie 5
Leiderschap 6
Risico inschatting en -behandeling 7
Ondersteuning 8
Uitvoering 9
Evaluatie van de prestaties 10
Meten en monitoren 10
Interne audit 10
Directiebeoordeling 10
Verbetering 11
Reageren op afwijkingen 11
Continue verbetering 11
Organisatorische maatregelen (A5) 12
Mensgerichte beheersmaatregelen (A6) 21
Fysieke beheersmaatregelen (A7) 23
Technologische beheersmaatregelen (A8) 26
Bijlage: Procedure meldplicht datalekken 34

Over dit document

Informatiebeveiliging is uitermate belangrijk voor onze organisatie, om fraude, bedrijfsonderbrekingen of gegevensverlies te voorkomen. Het management heeft besloten een informatiebeveiligingsbeleid aan te nemen met een aantal belangrijke maatregelen. Sommige van deze maatregelen zijn van toepassing op alle personeelsleden en worden beschreven in de personeelsrichtlijnen. Andere maatregelen zijn relevant voor specifieke beveiligingsrollen. Deze maatregelen worden beschreven in dit document. Dit document beschrijft per maatregel wat er moet gebeuren en wie verantwoordelijk is. Voor elke maatregel is een verantwoordelijke persoon en optioneel een back-up aangegeven.

Dit document maakt onderdeel uit van het [BEDRIJF] Information Security Management System (ISMS), een integrale aanpak van informatiebeveiliging. Voor meer details over dit ISMS, zie het document [BEDRIJF] Informatiebeveiligingsbeleid.

Dit document is opgezet als een centrale plaats waar alle procedures instaan. Iedereen die een procedure uitvoert moet dus bij dit document kunnen. Dit zijn bijvoorbeeld afdelingshoofden, IT-medewerkers en ook HR- of administratieve medewerkers. Dit document mag binnen [BEDRIJF] vrij worden verspreid. Het is niet bedoeld voor externe partijen.

Dit document wordt minimaal eens per jaar herzien. Het information security team houdt een werkversie bij met verbetervoorstellen. In de managementreview wordt deze nieuwe versie aan directie gepresenteerd en geaccordeerd. Dit document wordt vervolgens aan alle betrokkenen verspreid.

Deze versie is goedgekeurd in [MAAND_GOEDKEURING] [JAAR_GOEDKEURING] en geldt tot er een nieuwe versie is of tot en met [MAAND_GELDIG] [JAAR_GELDIG].

Structuur

Dit document volgt de hoofdstukken-structuur van ISO 27002. Eerst is de hoofdstructuur besproken, van H4-H10. Vervolgens zijn de beheersmaatregelen beschreven van A5 -A8.
Aan het einde zijn een aantal appendices toegevoegd. Dit zijn concrete werkinstructies voor specifieke processen. De volgorde is willekeurig.

Over dit template:

Dit template is gemaakt door de mensen van ICT Institute. Als je een opdrachtgever bent van ICT Institute, dan mag je alles doen met dit template wat je wilt

Het template mag gratis worden gebruikt, onder een creative commons licentie
https://creativecommons.org/licenses/by/4.0/

De nieuwste versie staat op:
https://softwarezaken.nl/2022/01/gratis-27001-avg-templates/

Je mag het template uitbreiden, aanpassen en bewerken zoveel je wilt
Je mag het template en documenten gemaakt met het template doorgeven en delen zoveel je wilt Als je het template doorgeeft, dan moet je "gemaakt door de mensen van ICT Institute" laten staan

Als je een document maakt met dit template en je bent geen opdrachtgever van ons, zet dan "gemaakt met template van ICT Institute" ergens in het document

Let op dat je de ISO 27001 norm moet kopen bij NEN of een andere organisatie voordat je de norm gaat gebruiken. De norm is auteursrechtelijk beschermd

Lees vooral ook deze artikelen als je aan de slag gaat:
https://softwarezaken.nl/2017/03/samenvatting-iso-27001-informatie-beveiliging/
https://softwarezaken.nl/2021/12/iso-27001-certificatie-aanvraag/
https://softwarezaken.nl/2018/01/gdpr-avg-in-10-stappen/
https://softwarezaken.nl/security-verified/

Inzicht in context en organisatie

Context en toepassingsgebied / scope

De scope van het ISMS is vastgelegd in het beleid.

Issues en belanghebbenden

De organisatie stelt jaarlijks interne en externe issues vast en legt deze vast in een register. Ook worden de stakeholders (belanghebbenden) en hun eisen en verwachtingen vastgesteld op het gebied van informatiebeveiliging. Al deze vastgelegde eisen worden ingevuld met het ISMS.

De vastgelegde issues en eisen zijn input voor de risico-analyse.

Leiderschap

De directie toont leiderschap en betrokkenheid bij het ISMS. Dit wordt onder andere gedaan door:

- Eindverantwoordelijkheid te nemen voor het ISMS
- Zorgen dat beleid en doelstellingen worden vastgesteld
- Zorgen dat de ISMS-eisen in de organisatie worden geïntegreerd
- Het zorgen voor voldoende menskracht en middelen
- Communiceren van het belang van het ISMS
- Zorgen dat gestelde doelen worden gehaald
- Actieve deelname aan training en overleggen van het ISMS
- Deel te nemen aan de directiebeoordeling
- Het bevorderen van continue verbetering
- De managers te ondersteunen om hun leiderschap te tonen binnen hun verantwoordelijkheidsgebieden

De directie stelt het Informatiebeveiligingsbeleid vast en zorgt dat het passend is voor de organisatie, doelstellingen bevat of een kader voor vaststellen doelstellingen, een commitment om te voldoen aan eisen en om continue te verbeteren. Het beleid wordt beschikbaar gesteld op de website en gecommuniceerd aan stakeholders wanneer nodig.

De directie wijst rollen en verantwoordelijkheden aan voor informatiebeveiliging. Deze zijn vastgelegd in dit handboek, bij beheersmaatregel A5.3.

Risico inschatting en -behandeling

De organisatie gebruikt een methodologie voor continue verbetering. Met behulp van deze methodiek is het informatiebeveiligingsteam op de hoogte van de bedrijfsdoelen, definieert het acties, controleert het of de acties effectief zijn en brengt het veranderingen aan indien nodig. De gekozen methode is Plan-Do-Check-Act, een bekende methodiek die ook wel de Deming-cyclus[1] genoemd wordt.

Voor de identificatie en aanpak van risico's gebruiken wij een risicobeheermethodologie waarbij risico's worden ingedeeld op basis van hun impact en waarschijnlijkheid. De risico's worden bijgehouden in het assets-en-risicoregister door het informatiebeveiligingsteam. In het register staat ook de risico-accectatiecriteria. De risico's zijn gebaseerd op de assets, issues en verwachtingen van stakeholders. In het risico-register staat de methode verder uitgewerkt.

Als een risico niet geaccepteerd wordt, wordt er een behandelplan gemaakt met duidelijke acties, uitvoerders en deadline. Het Informatiebeveiligingsteam bewaakt de voortgang van de behandeling.

Bij de behandeling wordt ook gekeken naar de toepasbaarheid van de standaard beheersmaatregelen. Er is een verklaring van toepasselijkheid waarin staat welke beheersmaatregelen zijn toegepast en waarom (vaak gebaseerd op de risico-analyse) of waarom niet en of de maatregel is geïmplementeerd. Van elk risico is de eigenaar genoteerd. De eigenaar geeft akkoord op acceptatie of het behandelplan.

Er worden ook doelstellingen vastgesteld, dit wordt gedaan in een apart register "Doelstellingen en monitoren". De doelstellingen worden regelmatig geëvalueerd in het IS-teamoverleg.

Als er wijziging in het ISMS nodig is, dan wordt dat besproken in het IS teamoverleg. Vervolgens wordt er een wijzigingsplan gemaakt om te zorgen dat de wijziging goed wordt uitgevoerd en de voortgang goed kan worden gecontroleerd.

Onder wijzigingen aan het managementsysteem voor informatiebeveiliging worden verstaan wijzigingen die significant zijn met mogelijke risico impact. Dit zijn onderhande wijzigingen met betrekking tot personele bezetting of rollen, veranderingen in de scope, veranderingen in het IT landschap, of nieuwe vormen van dienstverlening. Dit is geen uitputtende lijst maar wordt risicogebaseerd beoordeeld met in achtneming van de impact op de courante ISMS documenten.

[1] https://en.wikipedia.org/wiki/PDCA

Ondersteuning

De directie stelt middelen beschikbaar om de doelstellingen van het ISMS te bereiken. Dit blijkt onder andere uit de gedefinieerde rollen en alle in dit handboek omschreven maatregelen.

Er is een terugkerende awarenesstraining opgenomen in de jaarplanning. Nieuwe medewerkers krijgen ook een passende awareness-training.

Het Informatiebeveiligingsteam heeft hiervoor een regelmatig overleg (zie jaarplanning). Hierin wordt het volgende besproken:

- Incidenten: Zijn er incidenten geweest de afgelopen tijd en zijn passende acties gepland?
- Veranderingen: Zijn er nieuwe projecten, veranderingen of contracten waar het Informatiebeveiligingsteam naar moet kijken
- Jaarplanning: Welke activiteiten staan er voor afgelopen maand gepland in de jaarplanning? Zijn deze gepland en uitgevoerd?
- Monitoren en meten: Zijn er doelstellingen of KPI's die afgelopen maand of komende maand moeten worden geëvalueerd? Wat zijn de resultaten?
- Afwijkingen: Zijn er nieuwe afwijkingen? Worden er correctieve acties goed uitgevoerd op auditbevindingen of andere afwijkingen?

Beheer van documentatie: alle ISMS-documenten worden digitaal opgeslagen op een manier dat ze toegankelijk zijn voor de mensen die erbij moeten kunnen. Alle documenten hebben een versie, eigenaar en datum.

Uitvoering

Onze organisatie heeft een Informatiebeveiligingsteam dat de uitvoering van ISMS-acties monitort en zorgt dat doelen worden gehaald. Dit wordt gedaan door:

- Opstellen en volgen jaarplanning
- Bijhouden doelstellingen
- Bespreken van lopende acties en zaken in het Informatiebeveiligingsteam overleg.

In de overleggen wordt besproken of zaken goed lopen en eventueel maatregelen getroffen.

Evaluatie van de prestaties

Meten en monitoren

Er is een document “Doelstellingen en monitoren” waarin is vastgelegd welke zaken worden gemeten, inclusief hoe vaak en door wie.

Interne audit

(verplicht voor ISO 27001, niet voor security verified) De organisatie heeft een interne auditor aangesteld die jaarlijks interne audits uitvoert om informatie te verkrijgen of het managementsysteem voor informatiebeveiliging overeenkomt met de eigen eisen van het managementsysteem voor informatiebeveiliging; en de eisen van ISO 27001 en of het doeltreffend is geïmplementeerd

Directiebeoordeling

(verplicht voor ISO 27001, niet voor security verified) De organisatie voert jaarlijks een directiebeoordeling uit waarin de directie het managementsysteem voor informatiebeveiliging van de organisatie beoordeelt, om de continue geschiktheid, adequaatheid en doeltre doeltreffendheid te bewerkstelligen.

Hierin worden de volgende zaken besproken:

- de status van acties uit eerdere directiebeoordelingen;
- wijzigingen in externe en interne onderwerpen die relevant zijn voor het ISMS;
- wijzigingen in behoeftes en verwachtingen van belanghebbenden
- feedback over de informatiebeveiligingsprestaties, inclusief trends in:
    - afwijkingen en corrigerende maatregelen;
    - resultaten van monitoren en meten;
    - auditresultaten;
    - voldoen aan informatiebeveiligingsdoelstellingen;
- feedback van belanghebbenden;
- resultaten van risicobeoordeling en de status van het risicobehandelplan;
- kansen voor continue verbetering.

Beslissingen van directie worden in een verslag vastgelegd.

Verbetering

Reageren op afwijkingen

De organisatie legt alle voor het ISMS belangrijke afwijkingen vast in een Register afwijkingen en correctieve maatregelen.xlsx. Het Informatiebeveiligingsteam vult het register aan en zorgt dat er op de afwijking wordt gereageerd, deze wordt beoordeeld, grondoorzaken worden geëvalueerd en corrigerende maatregelen worden getroffen.

Afwijken kunnen geconstateerd worden tijdens:

- Monitoren en meten (9.1)
- Interne audits (9.2)
- Directiebeoordeling (9.3)
- Leveranciersbeoordeling
- Pen-testen
- Privacy-audits
- Interne meldingen
- Externe certificatie audits

Continue verbetering

Zowel de directie als het Informatiebeveiligingsteam spannen zich in om continue te blijven verbeteren, en nemen dit bijvoorbeeld mee in werkoverleggen, onderlinge gesprekken en contacten met andere medewerkers.

Organisatorische maatregelen (A5)

5.1 Beleidsregels voor informatiebeveiliging

We hebben een informatiebeveiligingsbeleid, genaamd [NAAM DOCUMENT]. Het bevat de context, doelen, scope van ons ISMS, en informatie over leiderschap, risicobeoordeling en -behandeling en natuurlijk ons streven naar continue verbetering.

Het informatiebeveiligingsbeleid wordt elk jaar beoordeeld (zie jaarplanning). Na een beveiligingsincident of grote wijziging in organisatiestructuur of -processen wordt het beleid ook tussentijds beoordeeld en eventueel bijgewerkt.

5.2 Rollen en verantwoordelijkheden bij informatiebeveiliging

Het gehele management is op de hoogte van het informatiebeveiligingsbeleid en is vastbesloten om deze inspanning op permanente basis te ondersteunen. Er is een informatiebeveiligingsteam (ook wel Informatiebeveiligingsteam , IS-team of Infosec-team genoemd) dat verantwoordelijk is voor het implementeren en onderhouden van informatiebeveiliging. Het team bestaat uit de volgende mensen:
1. A
2. B
3. C

De volgende taakomschrijving zijn belangrijk voor het ISMS:

Rol	Verantwoordelijkheid	Rol-eisen m.b.t. IB
CEO/algemeen directeur	Eindverantwoordelijk informatiebeveiliging. Vaststellen doelen en beleid	Opleiding? X jaar ervaring in een leidinggevende functie
CISO	Bijhouden van het ISMS om aan doelen en beleid te voldoen. Rapporteren status ISMS aan directeur	Afgeronde HBO- of academische opleiding Ervaring met IB-audits.
Privacy Officer	Controle op naleving AVG. Afhandeling datalekken en privacyvragen / verzoeken	CIPP/E of andere afgeronde privacytraining
CTO	Beheerder van externe IT-diensten. Verlenen / controleren rollen en rechten.	X jaar ervaring in een technische functie
Interne auditor	Uitvoeren van jaarlijkse interne audit	Ervaring met IB-audits. ISO 27001 lead auditor training
Alle medewerkers	Kennen en naleven van de regels en beleid informatiebeveiliging	

Alle andere personeelsleden van het bedrijf worden regelmatig geïnformeerd door het informatiebeveiligingsteam en zijn verantwoordelijk voor het volgen van het beleid en de richtlijnen.

5.3 Functiescheiding

We proberen om conflicterende taken en verantwoordelijkheden te scheiden. De volgende scheidingen zijn aangebracht:

- Developers met toegang tot broncode hebben geen beheersrechten in de productie-omgeving

- In het boekhoudsysteem zijn rollen zo ingesteld dat één iemand geen transactie kan doen zonder medewerking van anderen
- De FG is niet ook afdelingsmanager

5.4 Managementverantwoordelijkheden

Het management heeft van alle medewerkers geëist dat zij de informatiebeveiligingsregels tekenen en naleven. Ook moeten mensen het beleid en procedures volgen.

5.5 Contact met overheidsinstanties

Contacten met overheidsinstanties zijn als volgt:

- Belastingdienst: directeur
- Autoriteit Persoonsgegevens: privacy officer
- Politie bij aangifte diefstal: directeur

Overig contact met autoriteiten, bijvoorbeeld in het geval van andere inspecties of buitenlandse overheden, wordt afgehandeld door het management.

5.6 Contact met speciale belangengroepen

Het informatiebeveiligingsteam zorgt ervoor dat ze op de hoogte zijn van ontwikkelingen op het gebied van informatiebeveiliging. Dit wordt bijvoorbeeld op de volgende manier gedaan:

- De beveiligingsgroep voor informatiebeveiliging NL: https://www.linkedin.com/groups/13533313/
- Volgen van https://autoriteitpersoonsgegevens.nl en https://www.ncsc.nl
- Volgen van technische bron …

5.7 Informatie en analyses over dreigingen

Informatie over dreigingen wordt als volgt verzameld:

- Via volgen van nieuwsberichten via security.nl en ncsc.nl (andere bronnen: Microsoft MSRC, LinkedIn groups)
- Door meldingen in GitHub en GitLab over verouderde componenten

5.8 Informatiebeveiliging in projectmanagement

Voor elk groot klantproject of grote verandering in de organisatie wordt een plan gemaakt. Een grote verandering is gedefinieerd als een verandering die meer dan twee weken kost of waarbij meer dan twee mensen bij betrokken zijn.
Het plan moet de volgende secties bevatten:

- Beschrijving van projectdoelen.
- Veranderingen in het ISMS die nodig zijn.
- Beveiligingsmaatregelen in geval van belangrijke productwijzigingen.
- Privacy als nieuwe persoonlijke gegevens worden verzameld of persoonlijke gegevens op een nieuwe manier worden gebruikt.
- Of een DPIA nodig is.

5.9 Inventarisatie van informatie en andere gerelateerde bedrijfsmiddelen

Ons bedrijf gebruikt veel informatie-items die moeten worden beschermd. Het asset-en-risicoregister bevat een overzicht van de assets die in dit bedrijf worden gebruikt.

Alle assets in de inventaris, dus van het hele bedrijf als de inventaris compleet is, hebben een eigenaar. Het register wordt minimaal jaarlijks gecontroleerd (tijdens de risico-analayse) maar kan ook tussendoor worden bijgewerkt als er bijvoorbeeld door een project nieuwe middelen zijn bijgekomen.

5.10 Aanvaardbaar gebruik van informatie en andere gerelateerde bedrijfsmiddelen

Er zijn regels opgesteld voor het aanvaardbaar gebruik van bedrijfsmiddelen. Deze zijn opgenomen is de regels die door alle medewerkers worden getekend.

5.11 Retourneren (teruggeven) van bedrijfsmiddelen

Wanneer een werknemer of externe partij geen toegang meer dient te hebben tot een bedrijfsmiddel dan moet het middel worden teruggegeven. Dit kan bijvoorbeeld vanwege het einde van het dienstverband van de overeenkomst. Apparatuur kan worden ingevelerd bij de IT-manager, en wordt dan achter slot opgeslagen. Documenten of andere middelen kunnen aan eigenaar worden gegeven. Belangrijke unieke kennis moet bij vertrek van een medewerker worden gedocumenteerd.

5.12 Classificeren van informatie

Om onderscheid te maken tussen het belang van verschillende geclassificeerde assets, is het volgende onderscheid gemaakt:

- Openbaar
- Intern gebruik
- Vertrouwelijk

In de regels zijn voorbeelden opgenomen en regels voor elke gebruik. De verantwoordelijkheid voor het classificeren van informatie-assets ligt bij de eigenaar.

(ALS MEDISCHE DATA VERWERKT WORDT)
Alle patiëntinformatie dient als Vertrouwelijk gelabeld te worden.

5.13 Labelen van informatie

Documenten die wij zelf maken moeten zo veel mogelijk gelabeld worden met de juiste classificatie, om mensen te herinneren aan het zorgvuldig gebruikt. Dit kan vaak op een titelblad of in de header, en anders in de bestandsnaam of foldernaam.
Als documenten niet gelabeld zijn, moeten ze als vertrouwelijk worden beschouwd.

5.14 Overdragen van informatie

Informatie moet zorgvuldig worden overgedragen. Dit moet zoveel mogelijk binnen systemen worden gedaan volgens afgesproken bedrijfsprocessen. Als dit niet kan dan is overdracht via

email toegestaan, waarbij er mogelijk versleuteling moet worden toegepast (zie de instructies voor labeling in de regels).
Als er persoonsgegevens moeten worden uitgewisseld met een externe partij, wordt er eerst een verwerkersovereenkomst opgesteld.

5.15 Toegangsbeveiliging

Medewerkers krijgen toegang van het management op basis van hun rol volgens het Least Privilege principe. Het toegangsbeleid is vastgelegd in een autorisatiematrix voor rolgebaseerde toegang. Hierin staat zowel de fysieke toegang beschreven en toegang tot systemen.

5.16 Identiteitsbeheer

Iedere interne medewerker ontvangt een mail-adres van de organisatie. Toegang wordt verleent via dit adres, zodat dit adres als identitieit functioneert. De HR-verantwoordelijke wordt door de rest van het managementteam op de hoogte gehouden van wijzigingen in HR en maakt gebruikersaccounts aan wanneer een nieuwe medewerker in dienst treedt. Nadat een medewerker uit dienst is gegaan, deactiveert de HR-verantwoordelijke de gebruikersaccount.

5.17 Authenticatie-informatie

In de regels zijn ook regels opgenomen voor wachtwoorden. Dede moeten door mensen worden nageleefd. Waar mogelijk wordt het kiezen van wachtwoorden van voldoende lengte ook afgedwongen. Mensen ontvangen hun eerste wachtwoord bij voorkeur via een ander kanaal (bijvoorbeeld persoonlijk) dan hun inlognaam. Als dat niet kan, wordt gevraagd of zij het wachtwoord gelijk willen wijzigen

5.18 Toegangsrechten

Toegangsrechten worden verstrekt op basis van rol, zoals beschreven in de authorisatiematrix. De beheerder wijzigt of trekt toegangsrechten in binnen een week nadat een persoon vertrekt of van rol verandert. Een lijst met ingetrokken toegangsrechten is opgenomen in de checklist voor offboarding. In het geval van gedeelde wachtwoorden worden wachtwoorden actief gewijzigd.

Eigenaren van bedrijfsmiddelen controleren minimaal jaarlijks wie toegang heeft tot hun bedrijfsmiddel. Dit is opgenomen in de jaarplanning.

5.19 Informatiebeveiliging in relaties met leveranciers

We houden een register bij van leveranciers, waarin onze vereisten voor informatiebeveiliging, relevante documentatie en contactgegevens zijn opgenomen. Alle nieuwe leveranciers worden aan het register toegevoegd en het register wordt eenmaal per jaar gereviewd.

5.20 Informatiebeveiliging opnemen in leveranciers-overeenkomsten

Waar nodig volgens de beoordeling, wordt informatiebeveiliging opgenomen in overeenkomsten met leveranciers. Dit kan met een ‘data processing agreement’ / verwerkersovereenkomst met grotere leveranciers of via een geheimhoudingsclausule met freelancers. De eis per leverancier staat in het leveranciersoverzicht.

5.21 Informatiebeveiliging beheren in de toeleveringsketen van ICT

In verwerkersovereenkomsten is opgenomen dat leveranciers ook aan hun leveranciers informatiebeveiligingseisen opleggen, die voldoende zijn om het afgesproken niveau van beveiliging te bereiken.

5.22 Monitoring, herziening en wijzigingsbeheer van leveranciersdiensten

We controleren eenmaal per jaar de informatiebeveiliging van leveranciers voor alle relevante leveranciers. Hierbij wordt gekeken naar certificering als dat een eis is, en naar prestaties in de praktijk inclusief incidenten.
Als leveranciers niet aan onze beveiligingseisen voldoen, spreken we de leverancier aan en bij herhaling onderzoeken we alternatieve leveranciers. In het geval van wijzigingen in leveranciersovereenkomsten of dienstverleners, worden nieuwe diensten geïmplementeerd na analyse en beoordeling door de eigenaar van het bedrijfsmiddel en het management.

5.23 Informatiebeveiliging voor gebruik van clouddiensten

Clouddiensten zijn digitale diensten die via het Internet worden afgenomen, waarbij de leverancier hoofdzakelijk verantwoordelijk is voor technische inrichting en beheer. Vaak zijn clouddiensten gestandaardiseerd (generieke software ontwikkeld voor meerdere klanten).

Aanschaf
Voor cloudleveranciers gelden de normale eisen aan leveranciers, zoals ISO 27001 en VWO. Er wordt ook gekeken hoe lang leverancier en product bestaat en of er andere gebruikers bekend zijn. Als leverancier en product minder dan twee jaar bestaan, dan mag de dienst intern bij ICT Institute geprobeerd worden maar niet aan klanten worden geleverd.

Gebruik
Bij gebruik clouddiensten moet er op het volgende gelet worden:

- Gebruik eigen accounts en multifactor authenticatie
- Goed nadenken over wel/niet uploaden van documenten en hier per applicatie uitleggen wat wel/niet mag

Beheer
De IT-admin wordt een adminrol gegeven en controleert dat de applicatie goed wordt ingericht. Bijv toekenning juiste rollen aan alle gebruikers. De admin let ook op de kosten, door niet meer gebruikers te maken dan nodig

Beëindiging
Er moet voor ingebruikname gekeken worden naar exitmogelijkheden. Het gaat hierbij met name om het kunnen downloaden van alle opgeslagen data in een goed hanteerbaar formaat. Evt worden ook backups elders overwogen.

5.24 Planning en voorbereiding voor het beheer van informatiebeveiligingsincidenten

Een informatiebeveiligingsincident is een afzonderlijke gebeurtenis of een reeks informatiebeveiligingsgebeurtenissen waarvan het zeer waarschijnlijk is dat deze de bedrijfsactiviteiten compromitteren en de informatiebeveiliging in gevaar brengen.
Het informatiebeveiligingsteam analyseert meldingen van gebeurtenissen en bepaalt of het een incident is. Als dat het geval is, wordt het geregistreerd, wordt er actie ondernomen om schade te voorkomen. Alle incidenten worden besproken in het informatiebeveiligingsteam om toekomstige incidenten te kunnen voorkomen.

5.25 Beoordelen van en besluiten over informatiebeveiligingsgebeurtenissen

Het informatiebeveiligingsteam analyseert meldingen van gebeurtenissen en bepaalt of het een incident is. Zij doen dit direct na melding (zelfde dag of werkdag). De uitkomst wordt vastgelegd in het incidentenregister.

Een datalek is elke gebeurtenis waarbij persoonlijke gegevens mogelijk verloren gaan of worden gelekt naar de buitenwereld. Een dergelijk incident moet worden onderzocht en mogelijk worden gemeld aan de Autoriteit Persoonsgegevens (AP) en de betrokkenen die worden getroffen.

5.26 Reageren op informatiebeveiligingsincidenten

Als iets een incident is, wordt de rest van het informatiebeveiligingsteam op de hoogte gebracht. Er wordt directie actie ondernomen, zoals:

- Rechten intrekken
- Wachtwoord resetten
- Logs veiligstellen en bekijken
- Device blokkeren

Het team legt besluiten en acties vast in een kort verslag. Als het risico nog niet onder controle is, wordt ook management op de hoogte gesteld.
Het team gaat ook na of er sprake is van een datalek. Een datalek is elke gebeurtenis waarbij persoonlijke gegevens mogelijk verloren gaan of worden gelekt naar de buitenwereld. Een dergelijk incident moet worden onderzocht en mogelijk worden gemeld aan de Autoriteit Persoonsgegevens (AP) en de betrokkenen die worden getroffen.

Het is mogelijk dat een gebeurtenis alleen een kwetsbaarheid is maar er nog geen incident is waarbij er gebruik gemaakt is van de kwetsbaarheid. De kwetsbaarheid wordt dan geanalyseerd en een verbetering wordt gepland.
Bij diefstal of geslaagde cyberaanval wordt ook aangifte gedaan bij politie.

5.27 Leren van informatiebeveiligingsincidenten

Alle grote incidenten worden besproken door het informatiebeveiligingsteam. Zij bepalen de hoofdoorzaken en stellen aanvullende maatregelen voor.

5.28 Verzamelen van bewijsmateriaal

Technisch personeel bewaart een beschrijving van beveiligingsincidentenBij grote incidenten worden bewijsmateriaal (logbestanden, schermafbeeldingen, relevante mails, logbestanden) opgeslagen voor latere analyse of aangifte in een aparte folder voor bewijsmateriaal.

5.29 Informatiebeveiliging tijdens verstoring

We hebben een bedrijfscontinuïteitsplan waarin verschillende scenario's worden geanalyseerd, en gekeken wordt welke systemen nodig zijn om processen in stand te houden. Hierin is ook gekeken naar instandhouden van informatiebeveiliging. Ook de regels voor thuiswerken zijn zo opgesteld dat informatiebeveiliging gewaarborgd is als mensen door een verstoring thuis werken.

5.30 ICT-gereedheid voor bedrijfscontinuïteit

We hebben een bedrijfscontinuïteitsplan waarin verschillende scenario's worden geanalyseerd, en gekeken wordt welke systemen nodig zijn om processen in stand te houden. In het plan staan ook voor de hoofdprocessen de doelen, omschreven in de vorm van return time objectives (hersteltijd) en return point objectives (hoeveel uur aan data verloren mag gaan).
In dit plan zijn maatregelen opgenomen en is ook beschreven hoe de maatregelen worden getest. Deze test staat ook in de jaarplanning.

5.31 Wettelijke, statutaire, regelgevende en contractuele eisen

We hebben een overzichtsdocument van alle relevante wetgeving en contractuele vereisten. Hierin staat toepasselijke wetgeving en hoe deze is geïmplementeerd. Deze wordt jaarlijks herzien tegelijk met de belanghebbendenanalyse.

Hierin is opgenomen de AVG. Het is naar Nederlands recht verplicht dat een verwerkingsovereenkomst wordt ondertekend met elke leverancier die toegang heeft tot persoonlijke gegevens. [ROL] moet de relevante wetgeving en publicaties van de Autoriteit Persoonsgegevens lezen, een templateovereenkomst maken die moet worden gebruikt en ervoor zorgen dat overeenkomsten worden gesloten met elke bestaande en nieuwe leverancier.

5.32 Intellectuele eigendomsrechten

Wij respecteren intellectueel eigendom. Medewerkers moeten valideren of iets gebruikt mag worden voordat ze het gebruiken. Er mag geen gebruik worden gemaakt van illegale software of software zonder geldige licentie.

Teksten en afbeeldingen vallen onder het auteursrecht en we mogen niet alle teksten en afbeeldingen zomaar gebruiken. Het volgende is wel toegestaan:

- Je mag 1-2 zinnen per keer citeren met bronvermelding (naam van het document of URL). Hiervoor is geen toestemming nodig. Een screenshot van een website die je bespreekt is ook toegestaan.
- Je mag afbeeldingen gebruiken van creative commons bronnen zoals Noun Project, Unsplash of Wikimedia Commons. Vermeld de naam van de maker op dezelfde pagina of achterin het document. Andere afbeeldingen van internet zijn niet toegestaan.
- Voor foto's met herkenbare mensen heb je toestemming van de persoon nodig. Het makkelijkste is om geen foto's te gebruiken waarop mensen herkenbaar zijn.

5.33 Bescherming van registraties

De financiële administratie is beschermd tegen verlies, vernietiging, vervalsing, en toegang door onbevoegden door deze onder te brengen bij de externe accountant/administrateur. Broncode is beschermd tegen verlies, vernietiging en ongeoorloofde wijziging door het onderbrengen in een apart versiebeheersysteem.

5.34 Privacy en bescherming van persoonsgegevens

Persoonlijk identificeerbare informatie (PII), ook bekend als Persoonsgegevens, moet met de grootste zorg worden behandeld. Voorbeelden van PII zijn namen, telefoonnummers, e-mailadressen maar ook foto's waar mensen herkenbaar op staan. We gebruiken de volgende principes:

- De distributie en opslag van PII moet alleen gebeuren als het echt nodig is. Sla geen extra gegevens op.
- Gebruik alleen vertrouwde systemen voor de distributie en opslag van PII en kies niet zelf extra online tools die niet gecontroleerd zijn.
- We proberen om privacy by design toe te passen bij ontwikkelen of inrichten van systemen.

We hebben een register voor gegevensverwerking en hebben overeenkomsten voor gegevensverwerking. Ons privacybeleid is gepubliceerd op onze website. Er is een procedure voor het melden van een datalek.

We hebben we een [DPO of PRIVACY OFFICER]. Deze ziet er op toe dat wij aan alle wettelijke eisen voldoen die voortkomen uit de AVG, zoals een up-to-date verwerkingsregister, privacystatement en doen van een DPIA (gegevensbeschermings-effectbeoordeling). Een DPIA wordt uitgevoerd wanneer er sprake is van verwerking van bijzondere persoonsgegevens of grote verandering van onze werkwijze. Het volgende template wordt gebruikt: https://softwarezaken.nl/2018/03/avg-template-voor-dpia/

5.35 Onafhankelijke beoordeling van informatiebeveiliging

Eenmaal per jaar wordt een interne audit uitgevoerd door een onafhankelijke medewerker of externe consultant om te controleren of de werking van het ISMS voldoet. De resultaten worden aan het management gepresenteerd. Bij grote wijzigingen kan er een extra audit worden gedaan.

Informatiesystemen worden ook regelmatig gecontroleerd op naleving.

Kwetsbaarheidstests zoals penetratietests worden jaarlijks uitgevoerd.
ALTERNATIEF: Klanten, zoals [KLANTEN], kunnen verzoeken om (een partij in te huren om) een PEN-test uit te voeren op delen van ons systeem. Deze test mag alleen worden uitgevoerd met onze uitdrukkelijke schriftelijke toestemming en op door ons aangewezen/goedgekeurde delen van het systeem.

5.36 Naleving van beleid, regels en normen voor informatiebeveiliging

Alle managers worden geacht het beleid en de regels te kennen en toe te zien op de naleving. Als zij zien dat regels niet worden nageleefd of afgesproken procedures niet worden gevolgd, spreken zij mensen hierop aan. Bij herhaaldelijke problemen wordt ook het information security team geïnformeerd en wordt een afwijking gedocumenteerd of een incident indien van toepassing.

5.37 Gedocumenteerde werkprocedures

Als blijkt dat bepaalde werkzaamheden lastig zijn om goed en consistent uit te voeren zonder instructies, dan wordt er een werkinstructie gemaakt. Werkinstructies slaan we hier op: …

Mensgerichte beheersmaatregelen (A6)

6.1 Screening

De HR-verantwoordelijke controleert of voor functies, waar dit van toepassing is, een Verklaring-Omtrent Gedrag (VOG) wordt aangevraagd of dat referenties worden nagetrokken. De VOGs dienen de volgende categorieën te bevatten voor de volgende functieniveaus:

Functieniveau	Categorie geselecteerd
CISO, developer	11,12,13
Directie	11,12,13,22
CFO of financieel manager	22,71
Overige functies	VOG niet vereist. Linkedin wordt gecheckt
Stagiair	Controle of iemand een onderwijs-mail-adres heeft

De VOG-aanvraag kan aangevraagd worden via https://www.vog-aanvraag.nl (commerciële dienst). Bij de aanvraag kiest de werkgever het profiel volgens de tabel hierboven. De codes staan voor de volgende bevoegdheden:

- 11 - Bevoegdheid hebben tot het raadplegen en/of bewerken van systemen
- 12 - Met gevoelige/vertrouwelijke informatie omgaan
- 13 - Kennis dragen van veiligheidssystemen, controlemechanismen en verificatieprocessen
- 22 - Budgetbevoegdheid hebben
- 71 - Personen die vanuit hun functie mensen en/of een organisatie (of een deel daarvan) aansturen

De VOG wordt digitaal bewaard door HR.

6.2 arbeidsovereenkomst

De HR-verantwoordelijke is verplicht om een arbeidsovereenkomst (inclusief tijdelijke contracten en stagecontracten) volgens het afgesproken template op te stellen. In het template staat dat iemand verplicht is de regels informatiebeveiliging na te leven en dat er sancties zijn op bewust niet naleven van de regels.

Tijdens het onboarding-proces wordt een checklist gebruikt om ervoor te zorgen dat alleen geschikte werknemers worden aangenomen, werknemers worden voorzien van geregistreerde apparaten, de juiste documentatie wordt gelezen en ondertekend en dat ze toegang krijgen volgens het Least Privilege-principe en op basis van Need to Know volgens ons toegangsbeleid. [LINK CHECKLIST ON-BOARDING]

6.3 Bewustwording van, opleiding en training in informatiebeveiliging

De CISO zorgt er ook voor dat elke persoon in de eerste week een training of instructie voor informatiebeveiliging ontvangt. Er wordt ook minstens één keer per jaar een bewustmakingstraining of activiteit georganiseerd voor iedereen. Iedereen moet minstens één keer per jaar aan een bewustwordingsactiviteit meedoen. Als werknemers geen training hebben gehad, moeten ze contact opnemen met de Security Officer.

6.4 Disciplinaire procedure

In de regels staat duidelijk vermeld dat mensen verplicht zijn beleid en regels na te leven en dat er bij bewust niet naleven van de regels sancties zijn, zoals formele waarschuwingen. Leidinggevenden nemen in beoordelingsgesprekken alle belangrijke functie-aspecten mee, en dus ook of mensen regels en beleid voor informatiebeveiliging naleven.

6.5 Verantwoordelijkheden na beëindiging of wijziging van het dienstverband

Zelfs na het einde van het contract zijn medewerkers nog steeds verplicht om informatie veilig te houden: ze mogen geen gevoelige of vertrouwelijke gegevens openbaar maken aan buitenstaanders na vertrek uit het bedrijf. Dit is opgenomen in de geheimhoudingsclausule in contract. Bij uitdiensttreding ontvangt de werknemer die weggaat een herinnering aan deze verplichting. Dit is opgenomen op de checklist uitdienst-treding.

6.6 Vertrouwelijkheids- of geheimhoudingsovereenkomsten

In het contract voor werknemers die met vetrouwelijke gegevens werken (in principe iedereen) is een geheimhoudingsclausule opgenomen.
Met externe medewerkers en partijen worden conform het leveranciersbeleid passende afspraken gemaakt. Dit kan een contract met geheimhoudingsclausule zijn of een verwerkersovereenkomst. De overeenkomst of contract moet getekend zijn voordat er gegevens worden gedeeld.

6.7 Werken op afstand

Medewerkers mogen thuiswerken of werken op andere locaties dan kantoor, zolang ze zich houden aan wat er in de regels informatiebeveilging is vastgelegd. Hier staat onder andere in:

Je mag thuis werken of op derde locaties (restaurants, bij opdrachtgevers), zolang niemand met je scherm kan meelezen (shoulder surfing) of je gesprekken kan meeluisteren. (eavesdropping). Denk eraan je scherm te locken als je de laptop achterlaat.

6.8 Melden van informatiebeveiligingsgebeurtenissen

Alle medewerkers moeten informatiebeveilingsgebebeurtenissen melden aan het informatiebeveiligingsteam. Dit kan zoals in de regels informatiebeveiliging vastgelegd.

Fysieke beheersmaatregelen (A7)

7.1 Fysieke beveiligingszones

Hieronder is de plattegrond van het kantoor weergegeven. Hierop zijn zones aangegeven:

- Groen: toegankelijk voor bezoekers of medewerkers andere bedrijven in gebouw
- Geel: toegankelijk voor alle medewerkers, bezoekers alleen onder begeleiding
- Rood: afgesloten kast of ruimte, alleen toegankelijk voor een kleine groep beheerders / mensen met code/sleutel. Alleen in rode gebieden kan apparatuur of vertrouwelijke documenten worden opgeslagen.

[VOEG PLATTEGROND VAN KANTOOR MET ZONES IN]

7.2 Fysieke toegangsbeveiliging

Alle medewerkers hebben een sleutel/keycard om het gebouw te betreden of het kantoor in te komen. Er is wel/geen alarminstallatie.
De rode gebieden zijn afgesloten. Alleen de volgende rollen hebben een sleutel: ….

7.3 Beveiligen van kantoren, ruimten en faciliteiten beveiligen

Er is bescherming tegen meekijken op schermen door … (matglas, tussendeuren, schermen niet naar raam gericht).
Er is een alarminstallatie met de volgende kenmerken:
Andere genomen maatregelen zijn:

7.4 Monitoren van de fysieke beveiliging

In het gebouw zijn de volgende brandmelders en brandmaatregelen aanwezig:
Het gebouw heeft wel/geen noodstroomvoorziening tegen stroomuitval.
Ter bescherming tegen uitval telefonie, beschikken medewerkers die dit nodig hebben over telefoon met abonnement met voldoende data. Ook kan iedereen thuiswerken. De IT-systemen zijn vooral in de cloud ondergebracht en daardoor ook van buiten kantoor te benaderen.

7.5 Beschermen tegen fysieke en omgevingsdreigingen

[ORGANISATIE] schatten het risico op externe en omgevingsbedreigingen als laag in.
Al onze gegevens worden in de cloud opgeslagen en zijn op afstand toegankelijk als het fysieke kantoor niet beschikbaar is.
Alle medewerkers beschikken over de benodigde apparatuur voor thuiswerken.

7.6 Werken in beveiligde zones

De enige beveiligde zone bij [BEDRIJF] is de serverruimte. Hiervoor is een speciale sleutel nodig, die alleen bij [ROLLEN] in bezit zijn. De sleutels tot de afgesloten kast zijn alleen in bezit van [ROLLEN]. Medewerkers die niet geautoriseerd zijn om de beveiligde zone of kast

te betreden, mogen alleen onder begeleiding van een geautoriseerde collega tijdelijk toegang hebben.

7.7 Clear desk- en clear screen beleid

De organisatie heeft een clear desk en clear screen beleid. Dit is opgenomen in de regels informatiebeveiliging. De regels komen neer op het volgende:

Bij het verlaten van het kantoor moeten alle documenten van de bureaus worden verwijderd en op een niet-zichtbare manier worden opgeslagen. Vertrouwelijke documenten moeten worden opgeslagen in vergrendelde laden of archiefkasten.

Computers en telefoons moeten een schermbeveiliging hebben met een wachtwoord of een soortgelijke veiligheidsmaatregel (bijvoorbeeld een vingerafdruklezer). Medewerkers moeten apparaten altijd vergrendelen wanneer ze deze onbewaakt achterlaten.

7.8 Plaatsing en bescherming van apparatuur

Apparatuur moet veilig worden geplaatst en beschermd. Dit betekent dat kabels niet langer moeten zijn dan nodig en niet rond mogen slingeren, dat er geen spullen op of voor ventilatieroosters van apparatuur mag liggen, en apparatuur zo geplaatst moet zijn dat de kans op waterschade en op vallen minimaal moet zijn.

7.9 Beveiliging van bedrijfsmiddelen buiten het terrein

Apparatuur moet voldoende beschermd zijn buiten kantoor, zowel tegen externe factoren als weer en vervoer als tegen diefstal. Apparatuur mag buiten kantoor en thuis nooit onbeheerd achtergelaten worden, zelfs afgesloten niet.

7.10 Opslagmedia

Het gebruik van mobiele media (usb-sticks, externe disks) wordt sterk afgeraden. Deze media mogen alleen worden gebruikt met uitdrukkelijke toestemming van de Security Officer. Wanneer media niet langer nodig zijn (bijvoorbeeld afgekeurde computers met harde schijf) wordt het op de juiste manier verwijderd om het lekken van data te voorkomen. Bij voorkeur gaat dit via een gecertificeerde leverancier. Als deze niet beschikbaar is dan wordt de apparatuur opgeslagen.

7.11 Nutsvoorzieningen

Het gebouw waar ons kantoor gevestigd is, draagt zorg voor de nutsvoorzieningen; water, stroom, airconditioning, en internetaansluiting. Mochten deze voorzieningen falen, dan kunnen alle medewerkers thuis werken.

7.12 Beveiliging van bekabeling

De bekabeling binnen het gebouw wordt door de beheerder van het gebouw gelegd en beheerd. De router bevindt zich in de serverruimte, zodat er niet eenvoudig een apparaat aangesloten kan worden dat al het netwerkverkeer afluistert.

7.13 Onderhoud van apparatuur

Medewerkers dienen hun laptops en telefoons te updaten zodra de fabrikant een tussenupdate uitbrengt. De IT-admin draagt er zorg voor dat andere hardware, zoals de server, router, en access points up to date blijven en voert deze updates binnen een maand

na release door. Alle apparatuur dient zoals door de fabrikant beschreven gebruikt en onderhouden te worden.

7.14 Veilig verwijderen of hergebruiken van apparatuur

Devices kunnen op enig moment worden hergebruikt, maar het is belangrijk om dit proces goed te beheersen. Als een laptop of telefoon wordt ingeleverd, wordt alle informatie verwijderd. Dit kan bijvoorbeeld door een factory reset. Zie bijvoorbeeld deze instructie:
https://support.apple.com/en-us/108931
https://support.microsoft.com/en-us/windows/reset-your-pc-0ef73740-b927-549b-b7c9-e6f2b48d275e

Technologische beheersmaatregelen (A8)

8.1 User endpoint devices

Alle devices (laptops en telefoons) moeten passend beschermd worden. Dit betekent:

- Een up to date besturingssysteem
- Automatische updates enabled
- Bitlocker, Filevault of andere encryptie aangezet
- Wachtwoord of pincode aangezet.

We gebruiken hiervoor een Mobile Device Magament Oplossing: Intune, Miradore, …@@
Alle devices worden hierin aangemeld en van hieruit gecontroleerd.

8.2 Speciale toegangsrechten

Beheerderstoegang, admin-accounts en andere onbeperkte toegang (bijvoorbeeld database-wachtwoorden) wordt alleen gegeven aan een zeer beperkte reeks actieve beheerders die aanvullende instructies hebben ontvangen. Deze zijn gereserveerd voor platformbeheerders of IT-beheerders. Andere gebruikers worden alleen voorzien van normale, niet-beheerdersaccounts. MFA indien beschikbaar is verplicht. Waar mogelijk worden alerts aangezet zodat andere beheerders zien als een beheerder actief is. In de autorisatiematrix is aangegeven welke rol adminrechten mag hebben per systeem.

8.3 Beperking toegang tot informatie

Toegang is beperkt per systeem, zoals beschreven in de autorisatiematrix. Hierin is rol-gebaseerde toegang geregeld. Iedereen krijgt toegang gebaseerd op rol.

8.4 Toegangsbeveiliging op programmabroncode

Alle broncode wordt opgeslagen in [STORAGE_OPSLAG] in meerdere repositories. Developers krijgen alleen toegang tot repositories waar zij aan bijdragen. Niet-developers krijgen een rol met beperkte rechten.

8.5 Beveiligde authenticatie

Toegang wordt gegeven aan het officiële mailadres van iedereen, zodat bij uitdiensttreding toegang kan worden beheerst. Het gebruik van multifactorauthenticatie is verplicht. In alle systemen waar dit mogelijk is, zal dat ook worden afgedwongen.

8.6 Capaciteitsbeheer

We gebruiken het volgend systeem om het gebruik van rekenkracht en opslag in de gaten te houden:
Dit wordt gedaan door de volgende rol.
In … ontvangen we ook alerts.

8.7 Bescherming tegen malware

Alle computers (servers, pc's en laptops) moeten zijn uitgerust met een regelmatig bijgewerkte virusscanner en een firewall. Indien mogelijk moeten gebruikers worden belet scanners, firewalls uit te schakelen of andere beveiligingswijzigingen aan te brengen. In de training wordt aandacht besteed aan phishing en malware.

8.8 Beheer van technische kwetsbaarheden

We gebruiken de contacten met special interest groups om informatie te ontvangen over kwetsbaarheden en behandelen concrete meldingen als gebeurtenis / incident. In onze eigen software scannen we ook op kwetsbaarheden met …

Optie: Ten minste jaarlijks vindt een architectuurreview plaats, waarbij alle versies van belangrijke softwarecomponenten worden geïdentificeerd. Er wordt gevalideerd dat alle versies nog steeds worden ondersteund en dat dit de meest recente of de tweede meest recente versie is.

8.9 Configuratiebeheer

We gebruiken de volgende configuratie in onze organisatie:

- Configuratie van cloud-infrastructuur (bijv servers, databases)
- Configuratie van lokale apparatuur (bijv netwerk-apparatuur)

We beschermen configuratie op de volgende manieren:

- Configuratiebestanden ook opnemen in versiebeheer, net als broncode
- Het maken van backups van configuratie van apparatuur. Deze slaan we op in: ..@@@

Wijzigingen in de configuratie moeten worden beoordeeld door: senior systeem beheerder.

8.10 Wissen van informatie

Informatie die niet meer nodig is wordt actief verwijderd. Dit doen we bijvoorbeeld bijvoorbeeld voor:

- CV’s van niet aangenomen kandidaten. Deze worden na X maanden verwijderd.
- Omgevingen van vertrekkende klanten. Hier is een procedure voor die zorgt dat data maximaal X maanden bewaard wordt
- Verwijderen van financiële administratie na verstrijken wettelijke bewaartermijn (typisch 7 jaar na sluiten boekjaar). Dit wordt jaarlijks gedaan in maand ….
- Automatisch verwijderen backups. Dit is ingesteld in de cloud-omgeving/backuptool

8.11 Maskeren van gegevens

Wij beperken de blootstelling van gevoelige informatie met behulp van verschillende data masking technieken. De volgende technieken en principes worden toegepast:

- Toegangscontrole: alle medewerkers volgen het toegangscontrolebeleid om interne ongeoorloofde toegang tot informatie te voorkomen. Toegepast in …

- Rolgebaseerde toegang: Waar mogelijk hebben verschillende rollen toegang tot alleen velden / data die ze echt nodig hebben. Toegepast in …
- Encryptie: gegevens worden in rust en onderweg gecodeerd volgens onze encryptiestandaard. Toegepast in …
- Wachtwoordhashing: systemen en software slaan wachtwoorden gehasht op. Toegepast in …
- Product owners proberen masking toe te passen bij ontwerp, samen met het principe 'privacy by design'.

8.12 Voorkomen van gegevenslekken (data leakage prevention)

We gebruiken de volgende technische maatregelen om lekken te voorkomen:

- Het beperken van downloads van grote hoeveelheden data in systemen, bijvoorbeeld door massale downloads niet te ondersteunen. Toegepast in ….
- Het encrypten van devices zodat er geen data verloren gaat bij diefstal device
- Logging van download-acties. Toegepast in ….

Er is gekeken naar het instellen van regels in de mailomgeving om bepaalde mails niet direct te versturen (https://support.google.com/a/answer/14767988 https://learn.microsoft.com/en-us/purview/dlp-policy-reference-new-outlook). Dit is wel/ niet toegepast.

8.13 Back-up van informatie

Het beleid is om alle belangrijke data te backuppen, conform de doelen uit het business continuity plan. In dit plan staat de RPO en RTO van elk proces.
De backup wordt minimaal jaarlijks getest in een restore-test (zie jaarkalender).

8.14 Redundantie van informatieverwerkende faciliteiten

In de cloud hebben we gezorgd voor passende redundantie. We passen het volgende toe: [meerdere regio's, meerdere databases, load balancer].

8.15 Logging

Voor de belangrijke systemen worden foutmeldingen en andere zaken gelogd. Dit wordt gedaan in systeem: …
De logging wordt maandelijks bekeken door de beheerder. Indien er ongewone activiteit is, wordt dit besproken in het informatiebeveiligingsteam.

De logboeken moeten veilig worden opgeslagen, beschermd tegen manipulatie en waarschuwingen / meldingen bevatten voor onregelmatige activiteiten. De logboeken worden ten minste 30 dagen opgeslagen om onderzoek mogelijk te maken.

8.16 Monitoren van activiteiten

Er worden vanuit systemen alerts gestuurd bij de volgende gebeurtenissen

Het devteam/ de beheerder volgen de meldingen via mail/slack en nemen desgewenst actie.

8.17 Kloksynchronisatie

Op alle servers moet een tijdsynchronisatieservice zijn geïnstalleerd, zodat logbestanden nauwkeurige timinginformatie bevatten. Dit wordt afgehandeld door [SYSTEEM]. De volgende NTP-server wordt gebruikt:

8.18 Gebruik van speciale systeemhulpmiddelen

Programma's waarmee men beveiliging kan omzeilen, mogen niet zomaar worden gebruikt. De volgende maatregelen zijn genomen om te voorkomen dat niet-systeembeheerders deze tools gebruiken:

- Zorgen dat gebruikers niet zelf software kunnen installeren
- Firewall waardoor FTP en SSH niet beschikbaar zijn van buiten
- Whitelisting voor admin-login
- Tweefactorauthenticatie op adminaccounts
- Netwerkscheiding en monitoring

8.19 Software installeren op operationele systemen

Installatie van software op productie-systemen is strak gecontroleerd. Er is een gedocumenteerde procedure van hoe software wordt gecontroleerd vóór de installatie en wie de software installeert / bijwerkt / verwijdert en hoe. Serverinstallatie is zoveel mogelijk geautomatiseerd om gebruikersfouten te minimaliseren.

8.20 Beveiliging netwerkcomponenten

Alle netwerkcomponenten hebben wachtwoordbeveiliging op het admindashboard, zodat instellingen niet kunnen worden veranderd. Er zijn firewalls op beide kantoornetwerken, op gateways in de cloud, en laptops van medewerkers.

8.21 Beveiliging van netwerkdiensten

De netwerken zijn beschermd door een firewall, die de toegang beperkt.
Andere maatregelen (cloudflare, Web application firewall, logging netwerk)

8.22 Netwerksegmentatie

Er is een gescheiden gastnetwerk, namelijk [SSID NETWERK]. Gasten en andere bezoekers mogen alleen met dit netwerk verbinding maken. Medewerkers mogen alleen van het hoofdnetwerk [SSID NETWERK] gebruik maken. De twee netwerken zijn gescheiden. De wachtwoorden worden jaarlijks gewijzigd.

[BIJ NETWERKEN IN DE CLOUD]
[BEDRIJF] heeft de volgende virtuele netwerken in de cloud:

- Netwerk 1
- Netwerk 2

Een schematische weergaven van de netwerkarchitectuur is hier te vinden: [LINK DIAGRAM].

8.23 Toepassen van webfilters

Webfilters zijn ingesteld in Defender / InTune. Toegang tot malware of nietzakelijke websites is geblokkeerd.

Alternatief: Op laptops en in het netwerk, gebruiken we Quad9 gebruiken als DNS. Quad9 is een alternatieve Domain Name Server dienst die veel schadelijke websites blokkeert. Een korte uitleg door Quad9 zelf is:

Quad9 is a free service that replaces your default ISP or enterprise Domain Name Server (DNS) configuration. When your computer performs any Internet transaction that uses the DNS (and most transactions do), Quad9 blocks lookups of malicious host names from an up-to-the-minute list of threats. This blocking action protects your computer, mobile device, or IoT systems against a wide range of threats such as malware, phishing, spyware, and botnets, and it can improve performance in addition to guaranteeing privacy. The Quad9 DNS service is operated by the Swiss-based Quad9 Foundation, whose mission is to provide a safer and more robust Internet for everyone.

Quad9 heeft het IP-adres 9.9.9.9. Dit moet je in de settings opnemen als IP-adres voor DNS.
Het instellen wordt hier uitgelegd: https://quad9.net/support/set-up-guides
Je kunt controleren of het gelukt is via https://on.quad9.net

8.24 Gebruik van cryptografie

De volgende versleuteling is verplicht:

- Gebruik van https voor alle webverkeer;
- Voor e-mailbeveiliging wordt er regelmatig gecontroleerd met https://internet.nl Hierbij moet een score van minimaal 60% worden gehaald; Dit wordt bijgehouden onder meten/monitoring
- Voor de opslag op laptops en telefoons wordt ook encryptie gebruikt. Dit gaat met Bitlocker of de door Apple ingebouwde mogelijkheden.

We gebruiken certificaten van Let's encrypt / andere prok=vider. Deze worden door … aangemaakt en daar bijgehouden. Wijzigingen worden door de websitebeheerder gedaan. Het beleid is om de certificaten niet te exporteren.

Sleutels en wachtwoorden moeten voldoen aan de gestelde wachtwoordeisen. Bij voorkeur worden nieuwe wachtwoorden, met name voor adminaccouncts, gegenereerd via een programma dat is ontworpen voor het genereren van veilige sleutels. Bij voorkeur zijn dit, voor encryptie-toepassingen, random gegenereerde strings van 12 of meer tekens.

Wachtwoorden en andere sleutels moeten veilig worden opgeslagen in een wachtwoordbeheerder programma of op een andere veilige plaats. Zorg ervoor dat elke sleutel toegankelijk is voor ten minste twee personen om verlies van data of assets te voorkomen.

8.25 Beveiligen tijdens de ontwikkelcyclus

Systeemeigenaars, ontwerpers en beheerders worden geïnstrueerd over het belang van privacy en beveiliging door ontwerp. Als onderdeel van de instructie moeten ze leren dat ze verantwoordelijk zijn voor de volgende aspecten:

- Persoonsgegevens mogen niet worden verzameld wanneer ze niet nodig zijn, zonder reden of toestemming. Persoonsgegevens moeten veilig worden opgeslagen en beschermd worden, bijvoorbeeld gebruik van codering of hashen.
- Persoonsgegevens moeten na gebruik actief worden verwijderd, aangezien het niet is toegestaan ze langer dan noodzakelijk op te slaan.
- Bij software-ontwikkeling werken we met user stories, waarin acceptatie-eisen worden vastgelegd. Waar van toepassing wordt hierin beveiliging meegenomen, bijvoorbeeld controle invoer, rechtencontrole, logging, en juiste foutmeldingen

8.26 Toepassingsbeveiligingseisen

Alle websites die ontwikkeld worden, moeten geïnstalleerd met HTTPS-enabled. Ook API's of andere services moeten deze beveiliging hebben. Bij twijfel wordt getest met internet.nl.
Alle SaaS software moet multifactor-authenticatie bieden en ook rolgebaseerde toegang. Bij grotere systemen/leveranciers moet er ook sprake zijn van logging en moet de leverancier een ISO 27001-achtige certificering hebben.
Bij aanschaf van software wordt gekeken of de tool ondersteund wordt door een leverancier die al meer dan 12 maanden bestaat en meer dan 5 medewerkers heeft en beschikt over een privacy-verklaring.

8.27 Veilige systeemarchitectuur en technische principes

Voor het ontwerpen van nieuwe systemen geldt het volgende:

- Kies een bekende programmeertaal die vaker voor dit soort toepassingen wordt gebruikt, zoals:
- Gebruik bij voorkeur een bekend, onderhouden framework, zoals FastAPI, Flask, of Django voor python of Wordpress of Laravel voor PHP.
- Zoek uit wat de nog ondersteunde versies zijn van programmeertaal en framework en kies een recente, nog ondersteunde versie van dit framework.
- Zorg voor betrouwbare, veilige hosting in de cloud-omgeving.
- Zorg voor identificatie en authenticatie vanaf dag 1 voor zowel acceptatie als productie.
- Documenteer de architectuurkeuzes in het projectplan of op confluence

8.28 Veilig coderen

Alle medewerkers worden minstens jaarlijks getraind in de ontwikkeling van veilige software. De basis voor de training is de OWASP top 10.

Valideer alle input van users in de backend. Test op onredelijke lengte en onverwachte karakters.

- Zorg dat database-queries goed in elkaar zitten, door speciale functies om queries samen te stellen.
- Pas op bij weergeven van user input, dat er geen JavaScript, SQL, of andere scripting in de tekst
- staat. Zorg dat de code niet wordt uitgevoerd.
- Gebruik altijd authenticatie en autorisatie.
- Test op unhappy flows: verkeerde input, gebruikers met te weinig rechten, niet werkende functies.

- Zorg altijd voor logging van problemen en onverwachte zaken.
- Geef geen informatie in foutmeldingen
- Gebruik unieke usernamen, niet standaardnamen als admin, system, default.
- Stel eisen aan wachtwoorden, zoals minimale lengte 8 tekens en gebruik letters en cijfers

8.29 Testen van de beveiliging tijdens ontwikkeling en acceptatie

De organisatie gebruikt een agile proces als ontwikkelmethode, waarbij de product owner direct ontwikkelde features test en accepteert. Hierbij is ook aandacht voor beveiliging, door te testen op de regels voor veilig coderen.
Voor acceptatie van een nieuw systeem (typisch aan het einde van een project) wordt er getest op informatiebeveiliging. Er is minimaal een test met internet.nl, en handmatige tests op invoervalidatie.

8.30 Uitbestede systeemontwikkeling

Wij doen niet aan de uitbesteding van softwareontwikkeling.
Wij doen wel aan uitbesteding van softwareontwikkeling, en controleren door peer review de kwaliteit van ontwikkelde software. Contractueel stellen we eisen aan kennisniveau ontwikkelaars, en externe ontwikkelaars doen mee aan de developer training.

8.31 Scheiding van ontwikkel-, test-, en productieomgevingen

Voor alle grote IT-systemen moeten tests eerder in afzonderlijke testomgevingen worden uitgevoerd en kunnen wijzigingen of tests tijdens de productie worden uitgevoerd.
Ontwikkelaars hebben geen toegang tot de productieomgeving.

8.32 Wijzigingsbeheer

Alle wijzigingen in- en binnen de organisatie die van invloed kunnen zijn op de informatiebeveiliging worden gecontroleerd en goedgekeurd door het management. Dergelijke veranderingen kunnen bijvoorbeeld het gebruik van een nieuw systeem of een verandering in een belangrijk bedrijfsproces zijn.

8.33 Testgegevens

In acceptatie en testomgevingen wordt geanonimiseerde productiedata / fictieve data gebruikt. De test en acceptatieomgevingen zijn net zo goed beschermd als productieomgevingen. In de acceptatieomgevingen wordt minimaal vertrouwelijke informatie gebruikt, bij voorkeur alleen persoonsgegevens van bij project betrokken personen.

8.34 bescherming van informatiesystemen tijdens audits

Audits kunnen diepe toegang tot veel informatie vereisen, wat de dagelijkse activiteiten niet mag verstoren. Om een goede audit te garanderen gelden daarom de volgende regels:

- Alle auditors moeten een duidelijk auditplan hebben;
- Het auditplan moet minimaal een week van tevoren worden meegedeeld;
- Auditors mogen het scherm observeren en vragen stellen, de eigen medewerker bedient het scherm.

Bijlage: Procedure meldplicht datalekken

Een **datalek** is een inbreuk op de beveiliging die per ongeluk of op onrechtmatige wijze leidt tot de vernietiging, het verlies, de wijziging of de ongeoorloofde verstrekking van of de ongeoorloofde toegang tot doorgezonden, opgeslagen of anderszins verwerkte gegevens.

Een **persoonsgegeven** is elk gegeven dat herleidbaar is tot een natuurlijk persoon. Denk aan email, telefoonnummer, voornaam_achternaam, huisadres, kenteken, IP-nummer, bankrekeningnummer, MAC-adres, foto's met gezichten erop, inkomen, geboortedatum. Niet persoongegevens zijn gemiddeldes over grote groepen.

Afhandeling van meldingen mogelijke datalekken

Het informatiebeveiligingsteam is verantwoordelijk voor de procedure meldplicht datalekken. Elk beveiligingsincident moet worden gemeld bij het informatiebeveiligingsteam en wordt door het team gelogd en bestudeerd.

Voor elk datalek wordt deze procedure doorlopen:
1. Het team bestudeert het incident en bepaalt wat er wanneer en waar is gebeurd en welke apparatuur en partijen hierbij betrokken zijn geweest

2. Het team neemt indien relevant direct actie om het lek te dichten of te stoppen, of spoort IT-betrokkenen aan om dit direct te doen.

3. Het team bepaalt welke persoonsgegevens van hoeveel en welke personen er betrokken zijn. Als uitkomst hiervan wordt het aantal personen vastgelegd, welke soorten gegevens en of er sprake is van bijzondere gegevens.

4. Het team bepaalt wie de verantwoordelijke voor de gegevens is. Dit wordt bepaald door na te gaan hoe de gegevens zijn verkregen en door bestudering van alle verwerkersovereenkomsten waaronder de gegevens zijn doorgegeven.

5. Het team bepaalt uitsluitbaarheid: of het redelijkerwijs uit te sluiten is dat persoonsgegevens onrechtmatig zijn verwerkt. Dit is bijvoorbeeld het geval bij diefstal van een laptop die voorzien is van sterke encryptie.

6a. Als onze organisatie geen verantwoordelijke is maar verwerker, wordt er melding gedaan conform de contactgegevens in verwerkersovereenkomst.

6b. Als er sprake is van een datalek en wij de verantwoordelijke zijn, dan wordt het datalek gemeld via het webformulier bij de Autoriteit Persoonsgegevens. Dit moet indien mogelijk niet later dan 72 uur na ontdekking.

Vervolgens schatten we in of het melden aan betrokkenen mogelijk is. Als het mogelijk is om te melden, dit geen nadelen heeft voor betrokkenen en er geen sprake is van goede encryptie, worden het datalek gemeld aan betrokkenen.

Alle besluiten over bijvoorbeeld ernst, uitsluitbaarheid, wel/niet melden worden vastgelegd in een verslag over het incident.